

RELATÓRIO DE VULNERABILIDADES E MITIGAÇÕES

Projeto Interdisciplinar – Flex Automation

Curso: Ciência da Computação

Disciplina: Redes de Computadores e Cibersegurança

Professor orientador: Victor Rosetti

1. Apresentação

Este documento apresenta uma análise preliminar das principais vulnerabilidades identificadas na solução Flex Automation, desenvolvida como Projeto Interdisciplinar da turma de Ciência da Computação. O sistema tem como objetivo monitorar temperatura e umidade em ambientes inteligentes por meio de dispositivos IoT, MQTT, backend, aplicação web e aplicativo mobile, permitindo acompanhamento de leituras, alertas e histórico.

A análise foi feita com base na arquitetura do sistema e nos requisitos funcionais e não funcionais definidos para o projeto. Como o sistema ainda está em desenvolvimento, o foco deste relatório é registrar riscos esperados, seus impactos e as mitigações que devem ser aplicadas no código e na infraestrutura do projeto.

2. Visão geral da arquitetura considerada

A arquitetura do projeto é composta pelas seguintes camadas:

- Camada IoT: sensores ou simuladores publicando leituras de temperatura e umidade.
- Camada de comunicação: broker MQTT responsável pelo envio das mensagens.
- Camada de processamento: backend que consome os tópicos, valida payloads e persiste dados.
- Camada de apresentação: site e aplicativo mobile para monitoramento, alertas e histórico.
- Camada de administração: gerenciamento de ambientes, dispositivos, usuários e permissões.

3. Principais vulnerabilidades identificadas

A tabela a seguir resume as vulnerabilidades mais prováveis para a arquitetura do sistema e as medidas de mitigação que devem ser aplicadas.

Camada	Vulnerabilidade	Impacto	Mitigação proposta
MQTT / IoT	Publicação sem autenticação forte ou	Dispositivos não autorizados podem	Exigir autenticação, restringir tópicos com

	controle de acesso.	publicar leituras falsas ou invadir tópicos.	ACL e revisar credenciais por dispositivo.
MQTT / IoT	Mensagens sem validação de formato e conteúdo.	Dados corrompidos ou fora de faixa podem entrar no sistema e afetar dashboards e alertas.	Validar campos obrigatórios, tipo de dado, intervalo aceitável e rejeitar payload inválido.
Backend	API exposta sem controle de acesso adequado.	Qualquer cliente pode consultar ou alterar dados se não houver proteção.	Implementar autenticação, autorização por perfil e proteção por token/JWT.
Backend	Credenciais e segredos armazenados de forma insegura.	Vazamento de senhas, chaves ou tokens em repositórios e logs.	Usar variáveis de ambiente e nunca versionar segredos no código fonte.
Web / Mobile	Acesso sem sessão autenticada ou sem autorização por perfil.	Exposição de dados de ambientes e dispositivos para usuários indevidos.	Aplicar login, controle de sessão e regras de permissão por tipo de usuário.
Comunicação	Tráfego de dados sem criptografia adequada.	Interceptação ou alteração das leituras durante o envio.	Usar HTTPS na API e, quando aplicável, MQTT com TLS.
Dados	Ausência de saneamento de entrada.	Injeção de dados inválidos ou inesperados no backend e no banco.	Normalizar entradas, validar tipos e aplicar regras de integridade antes de persistir.
Operação	Falta de monitoramento e registro de eventos suspeitos.	Problemas de segurança podem demorar para ser identificados.	Criar logs de autenticação, publicação inválida, falhas e alterações administrativas.

4. Mitigações a serem implementadas no sistema

Com base nas vulnerabilidades mapeadas, o grupo definiu as seguintes ações prioritárias para o desenvolvimento do sistema:

- validar rigorosamente o payload MQTT antes de processar qualquer leitura;
- proteger o backend com autenticação e autorização por perfil;
- utilizar variáveis de ambiente para credenciais e chaves sensíveis;
- adotar HTTPS na API e TLS sempre que possível na comunicação;
- registrar logs de eventos relevantes para auditoria e rastreabilidade;
- rejeitar leituras fora de faixa e mensagens com campos ausentes;
- restringir o acesso aos dashboards e dados por tipo de usuário.

4.1 Relatório de progresso

Relatório de Progresso das Respostas	
Riscos Tecnológicos e de Hardware	Progresso
Atraso e Falha de Equipamentos (TEC-001)	95%
Desempenho dos Sensores em Produção (TEC-005)	100%
Riscos de Infraestrutura e Conectividade	
Conectividade IoT vs. Sistema Central (GER-003)	80%
Disponibilidade e Segurança na Nuvem (EXT-002)	100%

Resumo da Respostas		
Estratégia	Ações em Foco	Progresso
Mitigar	Redução de bugs críticos e estabilização de conexão.	100%
Prevenir (Evitar)	Validação de sensores no mercado e uso de tecnologias dominadas.	90%
Transferir	Contratação de seguros, garantias e suporte técnico especializado.	100%
Aceitar (Ativa)	Definição da reserva de contingência para substituição de componentes.	100%

5. Análise crítica

Como o sistema é distribuído e depende da comunicação entre dispositivos IoT, backend e interfaces de usuário, sua superfície de ataque é naturalmente maior do que a de uma aplicação isolada. Isso exige atenção especial à segurança na entrada de dados, no transporte das mensagens e no controle de acesso. Sem essas medidas, o projeto pode sofrer com leituras falsas, exposição de dados e manipulação indevida das informações coletadas.

Ao mesmo tempo, por se tratar de um projeto acadêmico em desenvolvimento, algumas mitigações podem ser aplicadas em camadas, priorizando primeiro as proteções mais importantes e de maior impacto prático. Essa abordagem permite que o sistema evolua de forma segura, sem comprometer o cronograma.

6. Conclusão

A análise realizada mostra que o projeto Flex Automation possui riscos de segurança típicos de uma solução IoT com comunicação em rede, múltiplas interfaces e persistência de dados. No entanto, esses riscos podem ser reduzidos com medidas relativamente simples de autenticação, validação, criptografia e controle de acesso. O relatório serve como base para orientar as próximas etapas da implementação e ajudar o grupo a desenvolver um sistema mais confiável e robusto.

Observação: este relatório foi elaborado com base na arquitetura do projeto e pode ser atualizado conforme novas funcionalidades forem implementadas.